

the security aspect of the Kerberos mechanism.

Client authentication with AS

Pre-requisite: The client and the AS will have a symmetric key called Client-LongLivedKey. The other components in the KDC infrastructure, other than AS and client, will have this key. Figure 1 gives a schematic representation of the flow of information during stage 1.

The step-by-step flow for stage 1 is given below.

- Client forms the request to AS with the following payload:
 - Authenticator = Encrypt [Timestamp of client machine, Client-LongLivedKey]
 - Payload = ClientId in plain text + Authenticator
- Authentication server checks for the Client-LongLivedKey in its database using 'ClientId' sent by the client in plain text. If it does not find it, the authentication fails. In either case, the authentication server fetches the Client-LongLivedKey.
- Authentication server decrypts the authenticator using Client-LongLivedKey as:
 - Decrypt [Authenticator, Client-LongLivedKey]
- If the decryption is successful, it

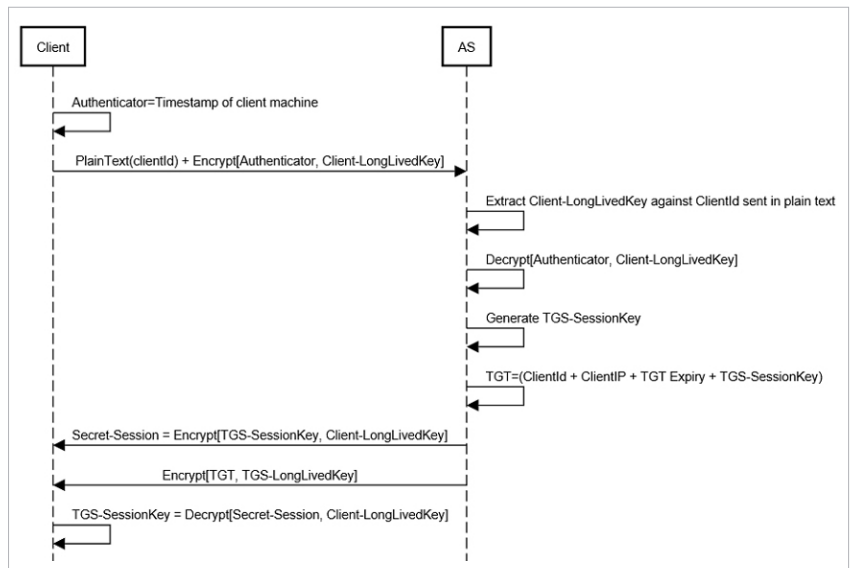


Figure 1: Client authentication with authentication server (KDC)

- confirms the client's identity.
- Authentication server creates the session key to be used by the client with the ticket granting service as 'TGS-SessionKey', and encrypts it using Client-LongLivedKey as:
 - Secret-Session = Encrypt [TGS-SessionKey, Client-LongLivedKey]
- Authentication server generates the TGT (ticket granting ticket) with the following parameters in it, and encrypts it using TGS-long lived key.
 - (TGT in plain text) = (ClientId + Client IP Address + TGS-SessionKey + Session key expiration information)
 - TGT = Encrypt [TGT in plain text, TGS-LongTermKey]
- Authentication server sends the complete payload to client as auth-response:
 - Auth-Response = (Secret-Session + TGT)
- Client receives the response and processes it as:

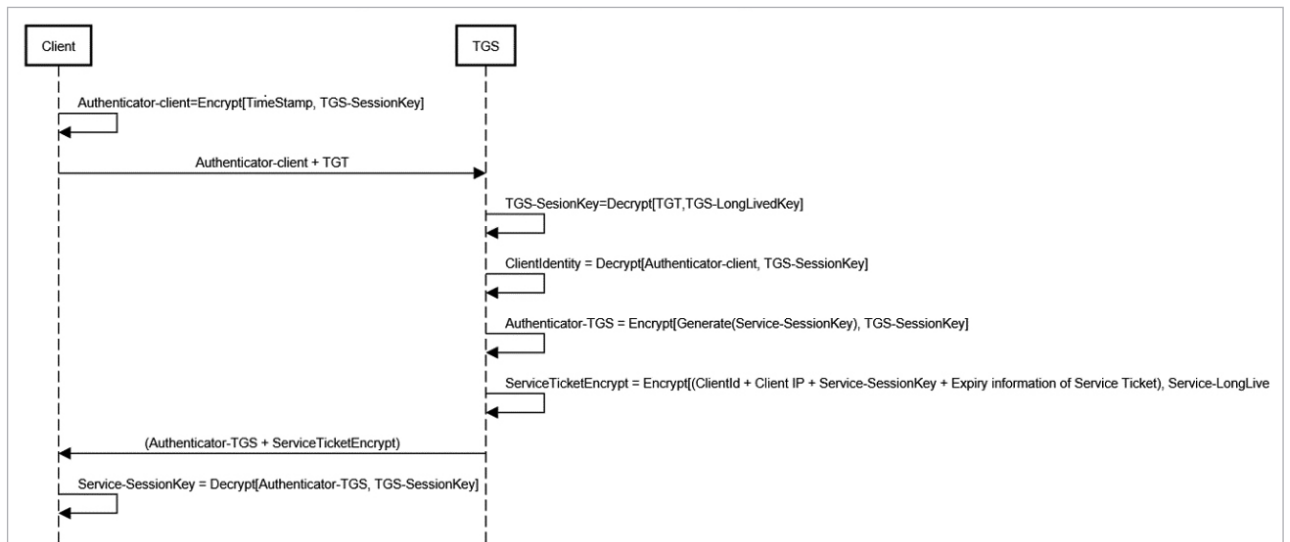


Figure 2: Client getting service ticket from TGS